

CIS Level 1 Windows Server 2022 Baseline Prioritization for AWS AMI Golden Image

Summary Statistics

Priority	Count	Focus Area
P0	50	Critical security controls for golden image
P1	60	High priority - immediate post-launch
P2	60	Medium priority - phased rollout
P3	40	Lower priority - environment specific

- **P0:** Absolute must-haves for the golden image (prevents initial compromise, credential theft, enables forensics)
- **P1:** High priority - should be in golden image or applied immediately at launch
- **P2:** Medium priority - can be applied via GPO post-deployment
- **P3:** Lower priority - environment-specific or defense-in-depth

P0: Critical Controls (Golden Image Must-Haves)

These 50 controls must be baked into the AMI. They prevent credential theft, initial compromise, and provide forensic visibility.

CIS Ref	Control	Current Status	Rationale
1.1.1	Enforce password history = 24 or more	FALSE	Prevents password reuse attacks
1.1.2	Maximum password age ≤ 365 days, not 0	TRUE	Forces credential rotation
1.1.4	Minimum password length ≥ 14 characters	TRUE	Brute-force resistance

CIS Ref	Control	Current Status	Rationale
1.1.5	Password must meet complexity requirements	TRUE	Prevents trivial passwords
1.1.7	Store passwords using reversible encryption = Disabled	TRUE	Prevents credential extraction
1.2.1	Account lockout duration $\geq$ 15 minutes	TRUE	Limits brute-force windows
1.2.2	Account lockout threshold $\leq$ 5 attempts, not 0	FALSE	Blocks automated attacks
1.2.4	Reset account lockout counter $\geq$ 15 minutes	TRUE	Sustains lockout protection
2.3.1.1	Guest account status = Disabled	TRUE	Removes anonymous access vector
2.3.1.2	Limit blank passwords to console logon only	FALSE	Blocks network auth with blank passwords
2.3.1.3	Rename administrator account	TRUE	Obscures high-value target
2.3.1.4	Rename guest account	TRUE	Obscures known account
2.3.7.2	Don't display last signed-in username	FALSE	Prevents username harvesting
2.3.10.1	Network access: Allow anonymous SID/Name translation = Disabled	FALSE	Blocks anonymous reconnaissance
2.3.10.2	Do not allow anonymous enumeration of SAM accounts	FALSE	Prevents user enumeration
2.3.10.3	Do not allow anonymous enumeration of SAM accounts and shares	FALSE	Prevents share enumeration
2.3.10.4	Do not allow storage of passwords and credentials for network authentication	FALSE	Prevents credential caching for network auth

CIS Ref	Control	Current Status	Rationale
2.3.10.5	Let Everyone permissions apply to anonymous users = Disabled	FALSE	Blocks anonymous privilege escalation
2.3.10.10	Restrict anonymous access to Named Pipes and Shares	FALSE	Closes null session attack vector
2.3.11.4	Configure encryption types allowed for Kerberos (AES only)	FALSE	Removes weak crypto (DES/RC4)
2.3.11.5	Do not store LAN Manager hash value	FALSE	Prevents LM hash extraction/cracking
2.3.11.7	LAN Manager authentication level = Send NTLMv2 only, refuse LM & NTLM	FALSE	Forces strong authentication
2.3.17.1	UAC: Admin Approval Mode for Built-in Administrator = Enabled	FALSE	Ensures admin elevation prompts
2.3.17.2	UAC: Elevation prompt for administrators = Prompt for consent	FALSE	Prevents silent privilege escalation
2.3.17.3	UAC: Elevation prompt for standard users = Automatically deny	FALSE	Blocks standard user elevation
2.3.17.6	UAC: Run all administrators in Admin Approval Mode	FALSE	Core UAC protection
2.3.17.7	UAC: Switch to secure desktop when prompting	FALSE	Prevents credential theft via UI spoofing
9.1.1	Windows Firewall: Domain: Firewall state = On	FALSE	Host-level network protection
9.1.2	Windows Firewall: Domain: Inbound connections = Block	FALSE	Default-deny inbound

CIS Ref	Control	Current Status	Rationale
9.2.1	Windows Firewall: Private: Firewall state = On	FALSE	Host-level network protection
9.2.2	Windows Firewall: Private: Inbound connections = Block	FALSE	Default-deny inbound
9.3.1	Windows Firewall: Public: Firewall state = On	FALSE	Host-level network protection
9.3.2	Windows Firewall: Public: Inbound connections = Block	FALSE	Default-deny inbound
9.3.5	Windows Firewall: Public: Apply local firewall rules = No	FALSE	Prevents rule tampering on public networks
17.5.4	Audit Logon = Success and Failure	FALSE	Critical for breach detection
17.5.6	Audit Special Logon = Success	FALSE	Detects privilege escalation
17.2.6	Audit User Account Management = Success and Failure	FALSE	Tracks account changes
17.1.1	Audit Credential Validation = Success and Failure	FALSE	Detects auth attacks
18.4.2	Configure SMB v1 client driver = Disabled	FALSE	Removes WannaCry/EternalBlue vector
18.4.3	Configure SMB v1 server = Disabled	FALSE	Removes SMBv1 attack surface
18.5.1	MSS: Enable Automatic Logon = Disabled	FALSE	Prevents credential caching
18.6.8.1	Enable insecure guest logons = Disabled	FALSE	Blocks guest auth bypass
18.10.57.3.9.4	RDP: Require Network Level Authentication	FALSE	Prevents unauthenticated RDP

CIS Ref	Control	Current Status	Rationale
18.10.57.3.9.5	RDP: Set client connection encryption level = High	FALSE	Enforces strong RDP encryption
18.10.87.1	Turn on PowerShell Script Block Logging	FALSE	Critical for PowerShell forensics
18.10.89.1.1	WinRM Client: Allow Basic authentication = Disabled	FALSE	Prevents credential theft
18.10.89.2.1	WinRM Service: Allow Basic authentication = Disabled	FALSE	Prevents credential theft
18.10.93.2.1	Configure Automatic Updates = Enabled	FALSE	Maintains patch compliance
2.2.21	Deny access from network to Guests/Local admin	FALSE	Blocks network auth for high-risk accounts
2.2.26	Deny RDP logon to Guests/Local account	FALSE	Blocks RDP for high-risk accounts

P1: High Priority (Golden Image or Immediate Post-Launch)

These 60 controls should either be in the golden image or applied immediately via GPO/SSM at instance launch.

CIS Ref	Control	Current Status	Rationale
1.1.3	Minimum password age ≥ 1 day	TRUE	Prevents rapid password cycling
1.1.6	Relax minimum password length limits = Enabled	FALSE	Supports 14+ character passwords
1.2.3	Allow Administrator account lockout = Enabled	FALSE	Protects built-in admin
2.2.1	Access Credential Manager as trusted caller = No One	FALSE	Prevents credential extraction

CIS Ref	Control	Current Status	Rationale
2.2.3	Access this computer from network = Administrators, Authenticated Users	FALSE	Restricts network access
2.2.4	Act as part of OS = No One	FALSE	Prevents token manipulation
2.2.7	Allow log on locally = Administrators	FALSE	Restricts console access
2.2.9	Allow log on through RDP = Administrators, Remote Desktop Users	FALSE	Restricts RDP access
2.2.14	Create a token object = No One	FALSE	Prevents token creation abuse
2.2.16	Create permanent shared objects = No One	FALSE	Prevents object creation abuse
2.2.19	Debug programs = Administrators	FALSE	Prevents memory debugging attacks
2.2.22	Deny log on as batch job to Guests	FALSE	Restricts batch job rights
2.2.23	Deny log on as service to Guests	FALSE	Restricts service rights
2.2.24	Deny log on locally to Guests	FALSE	Blocks local Guest logon
2.2.28	Enable computer/user accounts to be trusted for delegation = No One	FALSE	Prevents delegation abuse
2.2.30	Generate security audits = LOCAL SERVICE, NETWORK SERVICE	FALSE	Restricts audit generation
2.2.35	Lock pages in memory = No One	FALSE	Prevents memory attacks
2.2.38	Manage auditing and security log = Administrators	FALSE	Restricts audit log access

CIS Ref	Control	Current Status	Rationale
2.2.39	Modify an object label = No One	FALSE	Prevents label tampering
2.2.44	Replace a process level token = LOCAL SERVICE, NETWORK SERVICE	FALSE	Restricts token replacement
2.3.2.1	Force audit policy subcategory settings	FALSE	Enables granular auditing
2.3.6.1	Domain member: Digitally encrypt secure channel (always)	FALSE	Secures domain comms
2.3.6.2	Domain member: Digitally encrypt secure channel (when possible)	FALSE	Secures domain comms
2.3.6.3	Domain member: Digitally sign secure channel (when possible)	FALSE	Secures domain comms
2.3.6.4	Domain member: Disable machine account password changes = Disabled	FALSE	Maintains domain security
2.3.6.5	Domain member: Maximum machine account password age ≤ 30 days	FALSE	Forces domain credential rotation
2.3.6.6	Domain member: Require strong session key	FALSE	Enforces strong crypto
2.3.7.1	Do not require CTRL+ALT+DEL = Disabled	FALSE	Prevents credential theft
2.3.8.1	Microsoft network client: Digitally sign communications (always)	FALSE	Prevents SMB tampering
2.3.8.2	Microsoft network client: Send unencrypted password = Disabled	FALSE	Blocks cleartext auth
2.3.9.1	Microsoft network server: Amount of idle time before suspending ≤ 15 min	FALSE	Session timeout

CIS Ref	Control	Current Status	Rationale
2.3.9.2	Microsoft network server: Digitally sign communications (always)	FALSE	Prevents SMB tampering
2.3.9.3	Microsoft network server: Disconnect clients when logon hours expire	FALSE	Enforces logon restrictions
2.3.10.11	Restrict clients allowed to make remote calls to SAM	FALSE	Restricts SAM access
2.3.10.12	Shares that can be accessed anonymously = None	FALSE	Blocks anonymous shares
2.3.10.13	Sharing and security model = Classic	FALSE	Enforces authentication
2.3.11.2	Allow LocalSystem NULL session fallback = Disabled	FALSE	Prevents null session
2.3.11.3	Allow PKU2U authentication = Disabled	FALSE	Blocks online identity auth
2.3.11.6	Force logoff when logon hours expire	FALSE	Enforces logon hours
2.3.11.8	LDAP client signing requirements = Negotiate signing	FALSE	Secures LDAP
2.3.11.9	Minimum session security for NTLM SSP clients	FALSE	Enforces NTLMv2
2.3.11.10	Minimum session security for NTLM SSP servers	FALSE	Enforces NTLMv2
2.3.13.1	Allow system shutdown without logon = Disabled	FALSE	Requires auth for shutdown
2.3.17.4	UAC: Detect application installations	FALSE	Prompts for software install
2.3.17.5	UAC: Only elevate UIAccess apps in secure locations	FALSE	Prevents elevation attacks

CIS Ref	Control	Current Status	Rationale
2.3.17.8	UAC: Virtualize file/registry write failures	FALSE	Application compatibility
9.1.4	Windows Firewall: Domain: Display notification = No	FALSE	Silent operation
9.1.7	Windows Firewall: Domain: Log dropped packets = Yes	FALSE	Forensic visibility
9.2.4	Windows Firewall: Private: Display notification = No	FALSE	Silent operation
9.2.7	Windows Firewall: Private: Log dropped packets = Yes	FALSE	Forensic visibility
9.3.4	Windows Firewall: Public: Display notification = No	FALSE	Silent operation
9.3.9	Windows Firewall: Public: Log dropped packets = Yes	FALSE	Forensic visibility
17.5.1	Audit Account Lockout = Failure	FALSE	Detects brute-force
17.5.3	Audit Logoff = Success	FALSE	Session tracking
17.5.5	Audit Other Logon/Logoff Events = Success and Failure	FALSE	Comprehensive logging
17.7.1	Audit Audit Policy Change = Success	FALSE	Detects audit tampering
17.7.2	Audit Authentication Policy Change = Success	FALSE	Tracks policy changes
17.9.3	Audit Security State Change = Success	FALSE	Detects security changes
17.9.5	Audit System Integrity = Success and Failure	FALSE	Detects integrity violations
18.4.1	Apply UAC restrictions to local accounts on network logons	FALSE	Network UAC protection

CIS Ref	Control	Current Status	Rationale
18.4.4	Configure RPC packet level privacy	FALSE	Secures RPC
18.5.8	MSS: Enable Safe DLL search mode	FALSE	Prevents DLL hijacking
18.6.4.1	Configure DNS over HTTPS	FALSE	DNS privacy/security
18.10.6.1	Block Microsoft accounts	FALSE	Prevents consumer account sync
18.10.7.2	Set default behavior for AutoRun = Do not execute	FALSE	Prevents autorun malware
18.10.7.3	Turn off Autoplay = All drives	FALSE	Prevents autorun malware
18.10.81.2	Always install with elevated privileges = Disabled	FALSE	Prevents privilege escalation
18.10.89.2.4	Disallow WinRM from storing RunAs credentials	FALSE	Prevents credential caching

P2: Medium Priority (Post-Deployment via GPO)

These 60 controls are important but can be applied after initial deployment via Group Policy or configuration management.

CIS Ref	Control	Current Status	Category
2.2.6	Adjust memory quotas	FALSE	User Rights
2.2.11	Change system time	FALSE	User Rights
2.2.12	Change time zone	FALSE	User Rights
2.2.13	Create pagefile	FALSE	User Rights
2.2.15	Create global objects	FALSE	User Rights
2.2.18	Create symbolic links	FALSE	User Rights

CIS Ref	Control	Current Status	Category
2.2.29	Force shutdown from remote	FALSE	User Rights
2.2.32	Impersonate client after auth	FALSE	User Rights
2.2.33	Increase scheduling priority	FALSE	User Rights
2.2.34	Load/unload device drivers	FALSE	User Rights
2.2.40	Modify firmware environment	FALSE	User Rights
2.2.41	Perform volume maintenance	FALSE	User Rights
2.2.42	Profile single process	FALSE	User Rights
2.2.43	Profile system performance	FALSE	User Rights
2.2.45	Restore files/directories	FALSE	User Rights
2.2.46	Shut down system	FALSE	User Rights
2.2.48	Take ownership	FALSE	User Rights
2.3.4.1	Allowed to format removable media	FALSE	Device Security
2.3.4.2	Prevent users installing printer drivers	FALSE	Device Security
2.3.7.3	Machine inactivity limit ≤ 900 seconds	FALSE	Session Security
2.3.7.4	Message text for users	FALSE	Legal Notice
2.3.7.5	Message title for users	FALSE	Legal Notice
2.3.7.7	Prompt password change 5-14 days before	FALSE	Password Management
2.3.7.8	Require DC auth to unlock	FALSE	Domain Security
2.3.7.9	Smart card removal behavior	FALSE	Smart Card
2.3.9.4	Server SPN target name validation	FALSE	Kerberos Security
2.3.10.7	Named Pipes accessible anonymously	FALSE	Anonymous Access
2.3.10.8	Remotely accessible registry paths	FALSE	Registry Security

CIS Ref	Control	Current Status	Category
2.3.10.9	Remotely accessible registry sub-paths	FALSE	Registry Security
2.3.11.1	Allow Local System NTLM identity	FALSE	NTLM Security
2.3.15.1	Case insensitivity for non-Windows	FALSE	System Objects
2.3.15.2	Strengthen system object permissions	FALSE	System Objects
9.1.5	Domain firewall log path	FALSE	Firewall Logging
9.1.6	Domain firewall log size $\geq$ 16MB	FALSE	Firewall Logging
9.1.8	Domain firewall log successful	FALSE	Firewall Logging
9.2.5	Private firewall log path	FALSE	Firewall Logging
9.2.6	Private firewall log size $\geq$ 16MB	FALSE	Firewall Logging
9.2.8	Private firewall log successful	FALSE	Firewall Logging
9.3.3	Public firewall outbound = Allow	FALSE	Firewall Policy
9.3.6	Public apply connection security rules = No	FALSE	Firewall Policy
9.3.7	Public firewall log path	FALSE	Firewall Logging
9.3.8	Public firewall log size $\geq$ 16MB	FALSE	Firewall Logging
9.3.10	Public firewall log successful	FALSE	Firewall Logging
17.2.1	Audit Application Group Management	FALSE	Account Management
17.2.5	Audit Security Group Management	FALSE	Account Management
17.3.1	Audit PNP Activity	FALSE	System Monitoring
17.3.2	Audit Process Creation	FALSE	Process Monitoring
17.5.2	Audit Group Membership	FALSE	Logon Events
17.6.1	Audit Detailed File Share	FALSE	Object Access

CIS Ref	Control	Current Status	Category
17.6.2	Audit File Share	FALSE	Object Access
17.6.3	Audit Other Object Access	FALSE	Object Access
17.6.4	Audit Removable Storage	FALSE	Object Access
17.7.3	Audit Authorization Policy Change	FALSE	Policy Change
17.7.4	Audit MPSSVC Rule-Level Policy Change	FALSE	Policy Change
17.7.5	Audit Other Policy Change	FALSE	Policy Change
17.8.1	Audit Sensitive Privilege Use	FALSE	Privilege Use
17.9.1	Audit IPsec Driver	FALSE	System Events
17.9.2	Audit Other System Events	FALSE	System Events
17.9.4	Audit Security System Extension	FALSE	System Events
18.9.26.x	LAPS controls (4 controls)	FALSE	Password Management
18.10.14.1	Do not display password reveal button	FALSE	UI Security
18.10.14.2	Enumerate administrator accounts on elevation	FALSE	UI Security

P3: Lower Priority (Environment-Specific)

These 40 controls are lower priority for the golden image. Many are workstation-focused, application-specific, or provide defense-in-depth that can be added later.

CIS Ref	Control	Current Status	Category
2.3.2.2	Shut down if unable to log audits	FALSE	Audit Availability
2.3.7.4	Interactive logon message text	FALSE	Legal Notice

CIS Ref	Control	Current Status	Category
2.3.7.5	Interactive logon message title	FALSE	Legal Notice
18.1.1.1	Prevent lock screen camera	FALSE	Workstation UI
18.1.1.2	Prevent lock screen slide show	FALSE	Workstation UI
18.1.2.2	Online speech recognition	FALSE	Privacy
18.4.5	SEHOP	FALSE	Exploit Mitigation
18.4.6	NetBT NodeType	FALSE	Network Config
18.5.2	IPv6 source routing	FALSE	Network Security
18.5.3	IPv4 source routing	TRUE	Network Security
18.5.4	ICMP redirects	FALSE	Network Security
18.5.6	NetBIOS name release	FALSE	NetBIOS
18.5.9	Screen saver grace period	FALSE	Session Security
18.5.12	Security event log warning threshold	FALSE	Log Management
18.6.4.2	NetBIOS settings	FALSE	NetBIOS
18.6.4.3	Multicast name resolution	FALSE	Network Discovery
18.6.11.2	Network Bridge prohibition	FALSE	Network Config
18.6.11.3	Internet Connection Sharing	FALSE	Network Config
18.6.11.4	Elevate for network location	FALSE	Network Config
18.6.14.1	Hardened UNC Paths	FALSE	UNC Security
18.6.21.1	Minimize simultaneous connections	FALSE	Network Config
18.7.2	Redirection Guard	FALSE	Printer Security
18.7.3-7	RPC connection settings (5 controls)	FALSE	RPC Security

CIS Ref	Control	Current Status	Category
18.7.8-11	Print driver restrictions (4 controls)	FALSE	Printer Security
18.9.3.1	Include command line in process creation	FALSE	Audit Detail
18.9.4.1	Encryption Oracle Remediation	FALSE	RDP Security
18.9.4.2	Remote host delegation	FALSE	Credential Guard
18.9.7.2	Device metadata retrieval	FALSE	Privacy
18.9.13.1	Boot-Start Driver Init Policy	FALSE	Driver Security
18.9.19.2-5	Registry/Group Policy processing (4 controls)	FALSE	GPO Processing
18.9.20.1.1	Download print drivers over HTTP	FALSE	Printer Security
18.9.20.1.5	Web publishing wizards	FALSE	Legacy Features
18.9.24.1	Kernel DMA Protection	FALSE	Hardware Security
18.9.25.1	Custom SSPs/APs in LSASS	FALSE	Credential Guard
18.9.27.1-7	Sign-in UI settings (7 controls)	FALSE	UI Hardening
18.9.32.6.3-4	Password on wake (2 controls)	FALSE	Workstation Power
18.9.34.1-2	Remote Assistance (2 controls)	FALSE	Remote Support
18.9.35.1	RPC Endpoint Mapper Client Auth	FALSE	RPC Security
18.10.5.1	Microsoft accounts optional	FALSE	Account Type
18.10.7.1	Autoplay for non-volume devices	FALSE	Removable Media
18.10.8.1.1	Enhanced anti-spoofing	FALSE	Biometric
18.10.12.1/3	Cloud consumer experiences (2 controls)	FALSE	Privacy
18.10.13.1	PIN for pairing	FALSE	Bluetooth
18.10.15.1/3-8	Diagnostic data (7 controls)	FALSE	Privacy/Telemetry

CIS Ref	Control	Current Status	Category
18.10.17.1-4	App Installer (4 controls)	FALSE	Application Control
18.10.26.x	Event log sizes (8 controls)	FALSE	Log Management
18.10.29.2-4	Explorer protections (3 controls)	FALSE	Application Security
18.10.42.1	Block consumer MS account auth	FALSE	Account Security
18.10.51.1	OneDrive file storage	FALSE	Cloud Storage
18.10.57.2.2	Don't save passwords	FALSE	Credential Caching
18.10.57.3.3.3	Drive redirection	FALSE	RDP Features
18.10.57.3.9.1-3	RDP settings (3 controls)	FALSE	RDP Security
18.10.57.3.11.1-2	Temp folders (2 controls)	FALSE	RDP Session
18.10.58.1	RSS feed enclosures	FALSE	IE Security
18.10.59.3	Index encrypted files	FALSE	Search
18.10.76.2.1	Windows Defender SmartScreen	FALSE	Application Control
18.10.80.2	Windows Ink Workspace	FALSE	UI Features
18.10.81.1	User control over installs	FALSE	Software Restriction
18.10.82.1-2	MPR notifications/auto sign-in (2 controls)	FALSE	Logon Behavior
18.10.87.2	PowerShell Transcription	FALSE	Logging
18.10.89.1.2-3	WinRM Client unencrypted/digest (2 controls)	FALSE	WinRM Security
18.10.89.2.3	WinRM Service unencrypted	FALSE	WinRM Security
18.10.92.2.1	Users modifying settings	FALSE	Settings Control

CIS Ref	Control	Current Status	Category
18.10.93.1.1	Auto-restart with logged on users	FALSE	Update Behavior
18.10.93.2.2	Automatic Updates scheduled day	FALSE	Update Config
18.10.93.4.1-3	Preview builds/feature updates (3 controls)	FALSE	Update Config
19.1.3.1-3	Screen saver settings (3 controls)	FALSE	Workstation
19.5.1.1	Toast notifications on lock screen	FALSE	UI Settings
19.7.4.1-2	Zone information/AV notify (2 controls)	FALSE	Attachment Security
19.7.7.1/2/5	Windows spotlight (3 controls)	FALSE	UI Personalization
19.7.25.1	Sharing files within profile	FALSE	File Sharing
19.7.40.1	Always install with elevated privileges	FALSE	Software Installation

Post-Launch Configuration

Priority	Delivery Method	Timeline
P0	AMI baked settings	At image creation
P1	SSM Association / GPO	Within 1 hour of launch
P2	GPO / DSC	Within 24 hours
P3	GPO / Intune	As needed

AWS-Specific Additions (Not in CIS)

Control	Implementation
IMDSv2 Required	Instance metadata options
SSM Agent	Pre-installed and updated
CloudWatch Agent	Pre-installed for log shipping

Control	Implementation
EC2Launch v2	Modern launch agent
AWS PV Drivers	Latest version